# CRQ Vendor Validation Checklist

**Laura Voicu, PhD · laura.voicu@apropos-security.com · August 2026 · v1.0**

COMPANION TO *ERQI — Model Risk Testing & Analysis for Cyber Risk Quantification*

Commercial CRQ platforms increasingly claim to eliminate the need for expert judgment by integrating organizational telemetry, vulnerability data, threat intelligence, and external loss databases into automated loss estimates. Some of these platforms produce credible, well-constructed outputs. Others produce numbers from opaque models that cannot be examined, challenged, or independently reproduced — and the opacity is presented as a feature rather than acknowledged as a limitation.

The worst enemy of cyber risk quantification is not the skeptic who questions whether models can work. It is the precise-looking number produced from an unvalidatable process — whether by a commercial platform whose methodology is opaque or by an internal analyst whose assumptions have never been challenged — that trains decision-makers to trust outputs they cannot interrogate, and undermines the credibility of the entire discipline when those numbers prove wrong. Model risk is highest when the user cannot distinguish between a well-founded estimate and a confident guess.

This checklist provides a structured evaluation framework for organizations selecting or reviewing CRQ vendor platforms. It is organized around the principles established in *ERQI — Model Risk Testing & Analysis for Cyber Risk Quantification* — transparency, data quality, reproducibility, and uncertainty communication — adapted for the specific challenge of evaluating a model you do not own and may not be able to inspect. The companion *FAIR Validation Catalog* provides the equivalent assessment framework for analyst-driven FAIR models; both should be applied with equal rigor.

| 24 | 4 | 3 | 3 |
|---|---|---|---|
| QUESTIONS | SECTIONS | DECISION TIERS | BLOCKING CHECKS |

LICENSE · CC BY-NC-ND 4.0

© 2026 Laura Voicu. Licensed under Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 (creativecommons.org/licenses/by-nc-nd/4.0). You may copy and redistribute this document verbatim, with attribution, for non-commercial purposes. No derivative works. Using the checklist in your own work, including paid advisory, is welcome — please attribute. You may answer this checklist and share completed answers, including in commercial procurement between vendors and their customers. Selling the checklist itself, or distributing tools or documents derived from it, requires written permission from the author: laura.voicu@apropos-security.com. A fuller practitioner guide to these red flags exists — what each one means, what a good answer sounds like, and how to follow up. It is not part of the free set; contact the author for more details.

## 01 Transparency and Conceptual Soundness

The foundation of any model risk assessment is the ability to understand what the model does. For vendor platforms, this means understanding — at a conceptual level — how inputs map to outputs, what assumptions the

model makes, and where judgment or defaults substitute for data. A platform that cannot or will not explain its methodology is an unvalidatable risk.

| # | QUESTION | WHAT TO LOOK FOR | RED FLAG |
|---|---|---|---|
| **1.1** BLOCKING | Can the vendor explain how telemetry inputs map to loss estimates? | A documented, reviewable chain from input data to output distribution — not "proprietary algorithm" | "Our AI handles that" with no further explanation |
| **1.2** | Are the model's assumptions documented and accessible? | Written documentation of distributional assumptions, frequency models, severity models, aggregation logic | Assumptions are described only verbally or not at all |
| **1.3** | Can you identify which inputs drive the output? | Sensitivity analysis or tornado charts showing top drivers | All inputs appear to contribute equally, or sensitivity analysis is unavailable |
| **1.4** | Does the platform distinguish between data-driven and judgment-driven components? | Clear labeling of which outputs are calibrated from data and which reflect model assumptions or defaults | Everything is presented as "data-driven" with no acknowledgment of where judgment or assumptions fill gaps |
| **1.5** | What loss taxonomy does the platform use? | Defined, documented loss categories (direct costs, regulatory, litigation, reputation) with clear boundaries | Loss categories are undefined or aggregate everything into a single number |
| **1.6** | How does the platform handle secondary losses (regulatory fines, litigation, reputation)? | Separate estimation with documented methodology; ideally decomposed SLEF | Secondary losses are a fixed percentage of primary losses, or the methodology is undisclosed |

## 02 Data Quality and Provenance

A model's outputs are bounded by the quality of its calibration data. For vendor platforms, this means understanding not just what data sources the model uses, but how current they are, how censoring and truncation are handled, and whether the platform's claims about data completeness are credible. "Proprietary database" is not a data source.

| # | QUESTION | WHAT TO LOOK FOR | RED FLAG |
|---|---|---|---|
| **2.1** | What external loss data does the platform use? | Named, citable sources (IRIS, Advisen/ Cyentia, PRC, SEC filings) with documented vintages | "Proprietary database" with no source attribution |
| **2.2** | How current is the calibration data? | Documented data vintage; annual or more frequent updates | Data vintage is unknown or more than 2 years old |
| **2.3** | How does the platform handle censoring and truncation in insurance data? | Documented treatment of left-censoring (below retention) and right-truncation (above limit) | No mention of censoring/ truncation, or "we use raw claims data" |
| **2.4** | How does the platform adjust for underreporting? | Documented methodology or acknowledged limitation | Claims to have "complete" loss data |

| # | QUESTION | WHAT TO LOOK FOR | RED FLAG |
|---|---|---|---|
| 2.5 | What organizational telemetry does the platform ingest, and how is it weighted? | Documented mapping from telemetry signals (vulnerability counts, EDR alerts, control maturity) to model inputs | Telemetry ingestion is described but the mapping to risk outputs is opaque |
| 2.6 | Can you trace a specific output back to the data that produced it? | Data lineage from output to input sources | Outputs cannot be decomposed or traced |

## 03 Reproducibility and Implementation

A model that cannot be reproduced cannot be validated. For vendor platforms, full reproducibility may not be achievable — the model is proprietary — but directional validation (verifying that outputs respond correctly to input changes) and version stability (ensuring that past analyses can be revisited) are non-negotiable minimum standards. A platform that silently updates its model without notification is destroying the auditability of every prior analysis.

| # | QUESTION | WHAT TO LOOK FOR | RED FLAG |
|---|---|---|---|
| 3.1 | Can two runs with the same inputs produce the same outputs? | Deterministic mode or documented random seed for Monte Carlo | Outputs vary between runs with no explanation |
| 3.2 BLOCKING | Can the vendor demonstrate that outputs are reproducible, and provide sufficient documentation for directional validation? | Documented methodology enabling an independent analyst to verify that outputs move in the expected direction and magnitude when inputs change | No external validation is possible; the platform is a complete black box |
| 3.3 | Does the platform version-control its model? | Documented model versions with change logs; ability to re-run past analyses with past model versions | Model updates are applied silently; past results cannot be reproduced |
| 3.4 | How does the platform handle model updates? | Notification of material changes; impact assessment showing how outputs change under the new model | Model updates occur without user notification |
| 3.5 | Has the model been independently validated? | Third-party validation report available for review | “Our internal team validates continuously” with no independent review |
| 3.6 | Can the vendor demonstrate calibration against observed data? | Published or shared calibration studies — component-level validation (frequency against breach statistics, severity against claims data), benchmark reconciliation, or retrospective comparison where feasible | No calibration data available, or “our model is forward-looking” with no alternative validation evidence |

## 04 Uncertainty Communication and Fitness for Purpose

The most dangerous output a CRQ platform can produce is a precise number without context. Point estimates presented as definitive, narrow confidence intervals offered as evidence of model quality, and platforms that claim suitability for all decisions without qualification — these are not signs of a mature model. They are signs of a model that has not been subjected to the scrutiny it requires. A well-constructed platform acknowledges what it does not know and communicates the conditions under which its outputs should and should not be trusted.

| # | QUESTION | WHAT TO LOOK FOR | RED FLAG |
|---|---|---|---|
| **4.1** BLOCKING | Does the platform report uncertainty bounds, not just point estimates? | Ranges (P10–P90 or equivalent) for all key outputs | Single point estimates presented as definitive |
| **4.2** | Does the platform report both VaR and CVaR/TVaR? | Both risk measures available at relevant confidence levels | Only VaR, or only “expected loss” with no tail measure |
| **4.3** | Does the platform document conditions under which its outputs should not be used? | Explicit scope boundaries, data currency limits, and fitness-for-purpose statements | Platform claims to be suitable for all decisions without qualification |
| **4.4** | Can you run sensitivity analysis within the platform? | Ability to vary key inputs and observe output changes | Inputs are fixed by telemetry with no user override or sensitivity capability |
| **4.5** | Can you compare outputs under alternative model specifications? | Ability to test alternative distributional assumptions or scenarios | Single model specification with no alternatives |
| **4.6** | Does the platform distinguish between the precision of its output and the accuracy of its output? | Acknowledgment that narrow confidence intervals do not imply correctness — they may reflect model overconfidence | Narrow ranges presented as evidence of model quality |

## 05 Overall Vendor Assessment

| ASSESSMENT | CRITERIA |
|---|---|
| **Suitable for Level 1 decisions (capital, insurance, board risk appetite)** | Passes all Sections 1–4 checks; independent validation available; uncertainty quantification is comprehensive; model is reproducible and auditable |
| **Suitable for Level 2 decisions (control prioritization, scenario planning)** | Passes Section 1 and Section 4 checks; data provenance is documented; sensitivity analysis is available; some opacity in implementation is acceptable if compensated by benchmark reconciliation |
| **Suitable for Level 3 decisions only (screening, internal reporting)** | Basic transparency on methodology; outputs should not be used for material financial decisions without independent supplementary analysis |
| **Not suitable without remediation** | Fails 1.1 (cannot explain how inputs map to outputs), 3.2 (cannot reproduce outputs), or 4.1 (no uncertainty bounds). A model that cannot be examined, reproduced, or qualified should not inform any decision, regardless of assurance level |

© 2026 LAURA VOICU · CC BY-NC-ND 4.0

## 06 The Transparency Principle

A vendor's refusal to disclose model methodology on grounds of intellectual property is understandable in competitive terms but incompatible with model risk management. SR 11-7 is explicit: "the rigor and sophistication of model validation should be commensurate with the bank's overall use of models, the complexity and materiality of its models, and the size and complexity of the bank's operations." A model whose methodology cannot be reviewed cannot be validated. An unvalidated model should not inform material decisions.

This does not mean every vendor must publish its source code. It means that for any model used for Level 1 or Level 2 decisions, the organization must be able to understand — at minimum — what distributional assumptions the model makes, what data sources calibrate it, the conceptual architecture by which telemetry maps to loss estimates (not implementation details or proprietary weights, but the logical chain from input to output), and what the model's known limitations are. If the vendor cannot or will not provide this, the model should be classified as unvalidated and subject to compensating controls: conservative overlays, limits on use, and independent benchmarking against alternative approaches.

## References


Board of Governors of the Federal Reserve System (2011). SR 11–7: Supervisory Guidance on Model Risk Management. April 4, 2011.

Prudential Regulation Authority (2023). SS1/23: Model Risk Management Principles for Banks. May 2023. Effective May 2024.